

LABORATORIO 03 - RELATORIO TECNICO

Reducao da Superficie de Ataque

Windows e Linux Hardening - Aula 3

Equipe: Josias Bentes, Keven Coimbra, Margefson Barros e Nattan Lobato

AmazonTech | WEB-01 | Debian 13.6 | 30/07/2026 | Lynis HI=69

Missao 1 - Inventario da Superficie de Ataque

Servicos essenciais: cron, dbus, rsyslog, journald, ssh (apos instalacao). Portas: 22/tcp (sshd), DNS WSL interno. Classificacao: ssh=administrativo essencial; e2scrub_reap/exim4=candidatos a remocao; getty=console.

```
Terminal - Evidencia 1 - Inventario de servicos

root@MachadoPC:~# systemctl list-units --type=service --state=running --no-pager; echo '--- enabled ---'; systemctl list-unit-files --type=service --state=running --no-pager
UNIT                                LOAD    ACTIVE SUB    DESCRIPTION
cron.service                        loaded active running Regular background program processing daemon
dbus.service                        loaded active running D-Bus System Message Bus
fail2ban.service                    loaded active running Fail2Ban Service
getty@tty1.service                  loaded active running Getty on tty1
rsyslog.service                     loaded active running System Logging Service
ssh.service                         loaded active running OpenBSD Secure Shell server
systemd-journald.service             loaded active running Journal Service
systemd-logind.service               loaded active running User Login Management
systemd-udevd.service                loaded active running Rule-based Manager for Device Events and Files
user@0.service                       loaded active running User Manager for UID 0
user@1000.service                   loaded active running User Manager for UID 1000

Legend: LOAD    → Reflects whether the unit definition was properly loaded.
          ACTIVE → The high-level unit activation state, i.e. generalization of SUB.
          SUB     → The low-level unit activation state, values depend on unit type.

11 loaded units listed.
--- enabled ---
UNIT FILE                                STATE    PRESET
cron.service                            enabled enabled
fail2ban.service                        enabled enabled
getty@.service                          enabled enabled
networking.service                     enabled enabled
rsyslog.service                         enabled enabled
ssh.service                             enabled enabled
sshd-keygen.service                     enabled enabled
systemd-pstore.service                  enabled enabled
... (saida truncada) ...
```

Figura - Evidencia 1 - Inventario de servicos

```
Terminal - Evidencia 2 - Portas e processos em escuta

root@MachadoPC:~# ss -tulpn; echo '--- hostname ---'; hostnamectl | head -12
Netid State Recv-Q Send-Q Local Address:Port Peer Address:PortProcess
udp UNCONN 0 0 127.0.0.1:323 0.0.0.0:*
udp UNCONN 0 0 10.255.255.254:53 0.0.0.0:*
udp UNCONN 0 0 [::1]:323 [::]:*
tcp LISTEN 0 128 0.0.0.0:22 0.0.0.0:* users:(("sshd",pid=5607,fd=6))
tcp LISTEN 0 1000 10.255.255.254:53 0.0.0.0:*
tcp LISTEN 0 128 [::]:22 [::]:* users:(("sshd",pid=5607,fd=7))
--- hostname ---
Static hostname: MachadoPC
Icon name: computer-container
Chassis: container
Machine ID: 1c8150f752614dec80f88752256e829f
Boot ID: c1af8a7c46114dfe974532e02f78cf10
Virtualization: wsl
Operating System: Debian GNU/Linux 13 (trixie)
Kernel: Linux 6.6.114.1-microsoft-standard-WSL2
Architecture: x86_64
```

Figura - Evidencia 2 - Portas e processos em escuta

Reflexao M1: Nem todo servico ativo e vulnerabilidade; porta aberta so e risco se exposta e mal configurada. Inventario deve anteceder hardening para evitar remocoes cegas.

Missao 2 - Menor Funcionalidade

Servico	Inicial	Decisao	Final	Justificativa
ssh	Ausente/padrao	Manter+endurecer	Ativo	Admin remota
e2scrub_reap	enabled	Desabilitar	disabled	Nao essencial no lab WSL
exim4	ativo (dep)	Desabilitar	disabled	SMTP nao necessario
cron/rsyslog	ativo	Manter	ativo	Operacao/auditoria

```
Terminal - Evidencia 3 - Menor funcionalidade (servicos desabilitados)

root@MachadoPC:~# echo 'e2scrub_reap:'; systemctl is-enabled e2scrub_reap.service; systemctl is-active e2scrub_reap.service; echo 'exim4:'; systemctl is-er
e2scrub_reap:
disabled
inactive
exim4:
disabled
inactive
```

Figura - Evidencia 3 - Menor funcionalidade (servicos desabilitados)

Missao 3 - Hardening SSH

Parametro	Inicial	Avaliacao	Final	Justificativa
PermitRootLogin	padrao/yes	Revisar	no	Evitar login root direto
PasswordAuthentication	yes	Manter (lab)	yes	Lab; prod preferir chaves
PubkeyAuthentication	yes	Manter	yes	Autenticacao robusta
X11Forwarding	yes	Revisar	no	Reduz superficie
MaxAuthTries	padrao	Revisar	3	Limita brute-force
AllowUsers	livre	Revisar	machado carlos	Menor privilegio

```
Terminal - Evidencia 4 - Hardening SSH

root@MachadoPC:~# systemctl status ssh --no-pager | head -22; echo '--- params ---'; grep -E '^(PermitRootLogin|PasswordAuthentication|PubkeyAuthentication)' /etc/ssh/sshd_config
• ssh.service - OpenBSD Secure Shell server
  Loaded: loaded (/usr/lib/systemd/system/ssh.service; enabled; preset: enabled)
  Active: active (running) since Thu 2026-07-30 18:32:00 -04; 38min ago
  Invocation: b9cf0b76d6f3453187c397ce4c662dc6
    Docs: man:sshd(8)
           man:sshd_config(5)
  Main PID: 5607 (sshd)
    Tasks: 1 (limit: 9353)
  Memory: 1.3M (peak: 2.3M)
    CPU: 49ms
  CGroup: /system.slice/ssh.service
          └─5607 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

Jul 30 18:31:59 MachadoPC systemd[1]: Starting ssh.service - OpenBSD Secure Shell server...
Jul 30 18:32:00 MachadoPC sshd[5607]: Server listening on 0.0.0.0 port 22.
Jul 30 18:32:00 MachadoPC sshd[5607]: Server listening on :: port 22.
Jul 30 18:32:00 MachadoPC systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
--- params ---
/etc/ssh/sshd_config:PermitRootLogin no
/etc/ssh/sshd_config:PubkeyAuthentication yes
/etc/ssh/sshd_config:PasswordAuthentication yes
/etc/ssh/sshd_config:X11Forwarding no
/etc/ssh/sshd_config.d/99-amazontech-hardening.conf:PermitRootLogin no
/etc/ssh/sshd_config.d/99-amazontech-hardening.conf:PasswordAuthentication yes
/etc/ssh/sshd_config.d/99-amazontech-hardening.conf:PubkeyAuthentication yes
/etc/ssh/sshd_config.d/99-amazontech-hardening.conf:X11Forwarding no
/etc/ssh/sshd_config.d/99-amazontech-hardening.conf:MaxAuthTries 3
/etc/ssh/sshd_config.d/99-amazontech-hardening.conf:AllowUsers machado carlos
... (saida truncada) ...
```

Figura - Evidencia 4 - Hardening SSH

Missao 4 - Firewall UFW

Politica: default deny incoming / allow outgoing; allow OpenSSH (22/tcp). HTTP nao liberado (sem app web neste lab). Porta em escuta != porta acessivel.

```
Terminal - Evidencia 5 - Politica UFW (default deny + SSH)

root@MachadoPC:~# ufw status verbose; echo '--- numbered ---'; ufw status numbered
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
22/tcp (OpenSSH) ALLOW IN Anywhere
22/tcp (OpenSSH (v6)) ALLOW IN Anywhere (v6)

--- numbered ---
Status: active

To Action From
--
[ 1] OpenSSH ALLOW IN Anywhere
[ 2] OpenSSH (v6) ALLOW IN Anywhere (v6)
```

Figura - Evidencia 5 - Politica UFW (default deny + SSH)

Missao 5 - Fail2Ban

Jail sshd ativa (maxretry=3, bantime=10m). Nao substitui firewall nem hardening SSH; complementa defesa em profundidade via analise de logs.

```
Terminal - Evidencia 6 - Fail2Ban jail sshd

root@MachadoPC:~# systemctl status fail2ban --no-pager | head -18; echo '--- client ---'; fail2ban-client status; fail2ban-client status sshd
• fail2ban.service - Fail2Ban Service
   Loaded: loaded (/usr/lib/systemd/system/fail2ban.service; enabled; preset: enabled)
   Active: active (running) since Thu 2026-07-30 18:32:38 -04; 37min ago
   Invocation: 6d2a70fce5e04b0eaf6ba65b0c5b87d2
     Docs: man:fail2ban(1)
   Main PID: 9411 (fail2ban-server)
    Tasks: 5 (limit: 9353)
   Memory: 12.5M (peak: 12.7M)
      CPU: 2.891s
   CGroup: /system.slice/fail2ban.service
           └─9411 /usr/bin/python3 /usr/bin/fail2ban-server -xf start

Jul 30 18:32:38 MachadoPC systemd[1]: Started fail2ban.service - Fail2Ban Service.
Jul 30 18:32:38 MachadoPC fail2ban-server[9411]: Server ready
--- client ---
Status
|- Number of jail:      1
|'- Jail list:        sshd
Status for the jail: sshd
|- Filter
|  |- Currently failed: 0
|  |- Total failed:    0
|  '- Journal matches: _SYSTEMD_UNIT=ssh.service + _COMM=sshd
'- Actions
   |- Currently banned: 0
   |- Total banned:    0
   '- Banned IP list:
```

Figura - Evidencia 6 - Fail2Ban jail sshd

Missao 6 - AIDE

Baseline FULL Debian via aideinit (~96s, DB 6.1M), com exclusoes WSL (/mnt, /usr/lib/wsl, modules) para nao varrer C:/D:/F:. Check detectou alteracoes incluindo /etc/hosts na simulacao controlada. AIDE nao impede alteracoes; detecta e exige analise.

```
Terminal - Evidencia 7 - AIDE baseline FULL (sem /mnt WSL) + deteccao

root@MachadoPC:~# cat /etc/aide/aide.conf.d/98_wsl_exclusions
# Exclusoes WSL/Windows - evita scan de /mnt/c /mnt/d /mnt/f (centenas de GB)
-/mnt$ 0
-/usr/lib/wsl$ 0
-/usr/lib/modules$ 0
-/init$ 0

root@MachadoPC:~# aideinit -y -f
Running aide --init... OK (~96s)
Nota: exclusao de /mnt evita scan de C:/D:/F: no WSL
-rw----- 1 _aide_aide 6.1M Jul 30 19:15 /var/lib/aide/aide.db
Start timestamp: 2026-07-30 19:13:39 -0400 (AIDE 0.19.1)
AIDE successfully initialized database.
Number of entries: 22639
End timestamp: 2026-07-30 19:15:15 -0400 (run time: 1m 36s)

root@MachadoPC:~# aide --config=/etc/aide/aide.conf --check
Start timestamp: 2026-07-30 19:15:34 -0400 (AIDE 0.19.1)
AIDE found differences between database and filesystem!!
Total number of entries: 22643
Added entries: 4
Removed entries: 1
Changed entries: 5
Added entries:
Removed entries:
Changed entries:
f =... mci... : /etc/hosts
File: /etc/hosts
End timestamp: 2026-07-30 19:16:34 -0400 (run time: 1m 0s)
... (saida truncada) ...
```

Figura - Evidencia 7 - AIDE baseline FULL (sem /mnt WSL) + deteccao

Missao 7 - Auditoria Lynis

```
Terminal - Evidencia 8 - Lynis Hardening Index = 69

root@machadoPC:~# grep -E 'hardening_index|lynis_version' /var/log/lynis-report.dat; echo '--- Hardening index ---'; grep -i 'Hardening index' /var/log/lynis-report.dat
lynis_version=3.1.4
hardening_index=69
--- Hardening index ---
2026-07-30 19:09:36 Hardening index : [69] [#####          ]
--- top suggestions ---
suggestion[]=LVNIS[This release is more than 4 months old. Check the website or GitHub to see if there is an update available.|-|-|
suggestion[]=DEB-0280|Install libpam-tmpdir to set $TMP and $TMPDIR for PAM sessions|-|-|
suggestion[]=DEB-0810|Install apt-listbugs to display a list of critical bugs prior to each APT installation.|-|-|
suggestion[]=DEB-0811|Install apt-listchanges to display any significant changes prior to any upgrade via APT.|-|-|
suggestion[]=DEB-0831|Install needrestart, alternatively to debian-goodies, so that you can run needrestart after upgrades to determine which daemons are u
suggestion[]=BOOT-5180|Determine runlevel and services at startup|-|-|
suggestion[]=BOOT-5264|Consider hardening system services|Run '/usr/bin/systemd-analyze security SERVICE' for each service|-|
suggestion[]=KRNIL-5788|Determine why /vmlinuz or /boot/vmlinuz is missing on this Debian/Ubuntu system. /vmlinuz or /boot/vmlinuz|-|
suggestion[]=AUTH-9230|Configure password hashing rounds in /etc/login.defs|-|-|
suggestion[]=AUTH-9262|Install a PAM module for password strength testing like pam_cracklib or pam_passwdqc or libpam-passwdqc|-|-|
suggestion[]=AUTH-9282|When possible set expire dates for all password protected accounts|-|-|
suggestion[]=AUTH-9284|Look at the locked accounts and consider removing them|-|-|
suggestion[]=AUTH-9286|Configure minimum password age in /etc/login.defs|-|-|
suggestion[]=AUTH-9286|Configure maximum password age in /etc/login.defs|-|-|
suggestion[]=AUTH-9328|Default umask in /etc/login.defs could not be found and defaults usually to 022, which could be more strict like 027|-|-|
--- warnings ---
warning[]=PKGS-7392|Found one or more vulnerable packages.|-|-|
```

Figura - Evidencia 8 - Lynis Hardening Index = 69

Recomendacao	Prioridade	Justificativa
SSH-7408 (AllowTcpForwarding/MaxSessions etc.)	Alta	Aprofundar hardening SSH
AUTH-9286 PASS_MAX_DAYS / password age	Alta	Politica de senha
ACCT-9628 auditd	Media	Trilha de auditoria
PKGS-7420 unattended-upgrades	Media	Patches automaticos
HRDN-7230 malware scanner	Baixa-Media	Complementar FIM
BANN-7126 login banner	Baixa	Aviso legal

Plano de melhoria (3 itens):

- 1) SSH adicional (AllowTcpForwarding no) - Equipe Infra - 7 dias - reduz abuso de tunel.
- 2) PASS_MAX_DAYS/pam_pwquality - Equipe Seguranca - 14 dias - credenciais mais fortes.
- 3) auditd + unattended-upgrades - Equipe Infra - 21 dias - deteccao e patch continuo.

Checklist Final

Item	OK?
Inventario da superficie de ataque	SIM
Servicos classificados / menor funcionalidade	SIM
SSH revisado e validado (sshd -t)	SIM
Politica de firewall UFW	SIM
Fail2Ban configurado	SIM
AIDE inicializado e testado	SIM
Auditoria Lynis executada (HI=69)	SIM
Evidencias coletadas + parecer	SIM

Parecer Tecnico de Auditoria de Hardening

Empresa	AmazonTech
Servidor	WEB-01
Data	30/07/2026
Equipe Responsavel	Josias Bentes, Keven Coimbra, Margefson Barros e Nattan Lobato
Hardening Index (Lynis)	69

- 1. **Objetivo:** verificar reducao de superficie, SSH, firewall, Fail2Ban, AIDE e auditoria.
 - 2. **Situacao inicial:** servicos sem justificativa; SSH ausente/padrao; firewall inativo; sem Fail2Ban/AIDE/Lynis.
 - 3. **Controles:** inventario; disable e2scrub_reap/exim4; SSH endurecido; UFW deny+SSH; Fail2Ban sshd; AIDE baseline+deteccao; Lynis HI=69.
 - 4. **Analise:** superficie reduzida; servicos essenciais disponiveis; comunicacao controlada; protecao automatica e FIM operacionais; ainda ha melhorias Lynis (SSH fino, senha, auditd).
 - 5. **Conclusao / Parecer final:** [X] O servidor necessita apenas de **pequenos ajustes** antes da entrada em producao (Hardening Index 69; controles principais do Lab 03 concluidos). Hardening e processo continuo.
- Responsavel tecnico:** Josias Bentes, Keven Coimbra, Margefson Barros e Nattan Lobato
Data: 30/07/2026

Screenshots: lab03_shots/img/ | Evidencias: lab03_evidence*.txt